LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING

Daily 2026-10-26 Ivanti Connect Secure CVE-2026-104935 Active Exploitation Priority Update

CVE / Vulnerability Threat Intelligence Report

Classification	TLP:CLEAR
Published	2026-10-26
Version	1.0
Author	Lost Boys Cyber
Report Type	CVE / Vulnerability Threat Intelligence Report

Published: 2026-10-26 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Vulnerability Metadata
3. Source Review & Confidence
4. Vulnerability Details
5. Attack Scenarios
6. Threat Landscape & Exploitation Status
7. Affected Products and Exposure
8. Mitigation and Workarounds
9. Detection Engineering
10. Threat Hunting
11. MITRE ATT&CK Mapping
12. Validation / Lab Testing
13. Recommended Actions Summary
14. References

Daily 2026-10-26 Ivanti Connect Secure CVE-2026-104935 Active Exploitation Priority Update

1. Executive Summary

CVE-2026-104935 is an Ivanti Connect Secure (ICS) authentication-bypass-by-spoofing vulnerability. Ivanti's 13 October advisory, Rapid7's technical review, and CISA KEV reporting summarized by BleepingComputer establish a high-confidence operational priority: vulnerable remote-access appliances should be treated as potentially exposed before remediation, not merely as routine patch targets. CISA KEV inclusion was reported on 14 October.

The reviewed sources support emergency remediation and retrospective investigation. They do not establish that every exposed appliance was compromised, nor do they provide a universal, validated IOC set. Inventory externally reachable ICS systems, apply Ivanti's current remediation, restrict administration paths, retain appliance and identity telemetry, and investigate anomalous authentication, configuration, and credential-access events.

2. Vulnerability Metadata

Field	Value
CVE	CVE-2026-104935
Product	Ivanti Connect Secure (ICS)
Class	Authentication bypass by spoofing (CWE-290)
Vendor severity	High; Rapid7 reports CVSS v3.0 8.6
Disclosure	13 October 2026 (Ivanti advisory, per Rapid7)
Exploitation status	Reported active exploitation and CISA KEV addition; emergency priority
Scope caveat	Confirm affected/fixed versions and mitigations in the current Ivanti advisory

3. Source Review & Confidence

Source	Contribution	Confidence
Ivanti advisory (via Rapid7 analysis)	Product, class, disclosure and remediation context	High
Rapid7 ETR	Technical analysis and severity context	High
CISA KEV / BleepingComputer coverage	Active-exploitation prioritization and federal remediation urgency	High

4. Vulnerability Details

Rapid7 describes an authentication bypass by spoofing affecting ICS. Remote-access appliances are high-value because they commonly terminate trusted remote sessions and may store or broker access to enterprise services. The risk is therefore driven by exposure and trust placement as well as the CVSS score. Administrators must use the vendor advisory—not this summary—for fixed-version decisions and any product-specific mitigation sequence.

5. Attack Scenarios

- An internet-facing appliance receives crafted requests intended to bypass expected authentication checks.
- A threat actor uses the appliance foothold to enumerate remote-access configuration, active sessions, or connected identity infrastructure.
- An operator patches but does not review the pre-patch window, leaving abused accounts, sessions, web shells, or altered configuration undetected.

6. Threat Landscape & Exploitation Status

KEV inclusion is a prioritization signal, not proof of compromise. The evidence reviewed supports assuming exploit attempts are plausible against exposed systems. Preserve evidence before resets or upgrades where feasible; compare activity to approved maintenance windows and normal administrator source networks.

7. Affected Products and Exposure

Exposure pattern	Priority	Defender action
Internet-reachable ICS	Critical	Apply Ivanti remediation and restrict management exposure immediately
ICS reachable from partner/VPN networks	Critical	Review trust paths, MFA, administrator sources and segmentation
Patched appliance with no historical review	High	Hunt the exposure window and rotate/revalidate privileged access
Unsupported or unknown version	Critical	Escalate to platform owner and obtain vendor-supported remediation

8. Mitigation and Workarounds

1. Identify every ICS appliance, public IP/DNS name, software release, owner, and management path.
2. Apply the current Ivanti remediation under emergency change control; verify the installed version after the change.
3. Limit administrative interfaces to dedicated, logged management networks and require MFA.
4. Preserve authentication, admin, configuration, web-request, and appliance process telemetry before cleanup.
5. Revalidate administrator accounts, API/service credentials, active sessions, and federation configuration.
6. Do not perform exploit validation against production systems under this report.

9. Detection Engineering

Signal	Telemetry	Analytic goal
Authentication success from novel source	ICS auth logs, VPN, IdP	Identify anomalous remote-access use
Admin/configuration change	ICS audit logs	Detect post-access manipulation
Web request anomalies to appliance	Reverse proxy/WAF/ICS access logs	Identify exploit probing and unusual paths

```
DeviceNetworkEvents
| where Timestamp > ago(30d)
| where RemotePort in (443, 8443)
| where RemoteUrl has_any ("ivanti", "connect", "pulse")
| summarize Connections=count(), FirstSeen=min(Timestamp), LastSeen=max(Timestamp) by DeviceName,
RemoteUrl, RemoteIP, InitiatingProcessAccountName
| order by LastSeen desc
```

10. Threat Hunting

Hypothesis: Pre- or post-remediation appliance compromise or account abuse will produce unusual ICS authentication, privileged configuration, or identity events outside approved administrator patterns.

```
SigninLogs
| where TimeGenerated > ago(30d)
| where AppDisplayName has_any ("Ivanti", "Connect Secure", "VPN")
| summarize Attempts=count(), IPs=make_set(IPAddress, 20), Apps=make_set(AppDisplayName, 10) by
UserPrincipalName, ResultType
| order by Attempts desc
```

Validate results with appliance logs and approved change records; generic endpoint/identity data cannot prove CVE exploitation.

11. MITRE ATT&CK Mapping

Technique	Name	Rationale
T1190	Exploit Public-Facing Application	Exposure hypothesis for public appliances
T1078	Valid Accounts	Relevant to follow-on remote-access abuse
T1098	Account Manipulation	Hunt focus for altered access after foothold

12. Validation / Lab Testing

No exploit, scan, or production validation was performed. Validation consisted of multi-source review and detection-logic review. Operators should validate the vendor-prescribed fixed release and access controls in an approved environment.

13. Recommended Actions Summary

Priority	Owner	Action
Critical	Remote access owner	Inventory and remediate exposed ICS appliances
Critical	Network security	Restrict public and administrative paths
High	SOC	Review appliance/authentication/configuration telemetry
High	IAM	Revalidate privileged accounts and sessions

14. References

See `sources.md` and `references.md` for URLs, source roles, and reporting limitations.